

Industrial Security (Master)

Solution Sheet – Section 04 Offensive ICS in Authorised Labs

Exercise 4.1 – ROE (mark scheme)

Pass requires: named scope, explicit forbidden actions (especially around safety), kill-switch contact reachable 24/7, and an end-of-engagement evidence-handover process. Deduct for vague language (“best-effort”, “where possible”).

Exercise 4.2 – Recon Plan (mark scheme)

Strong answers privilege *passive* sources and explain why – ICS devices are fragile, scans can trip safety. Active probes are limited to known-safe NSE scripts at low rates.

Exercise 4.3 – Attack Path (sample)

Modbus write example:

- Pre-conditions: L2 reach to PLC, no write allow-list.
- Steps: pymodbus write_coil to set point, observe HMI.
- Process impact: pump cycles unexpectedly, alarm chain fires.
- Detection: industrial firewall log (DPI), Zeek ModbusWatch::Unsolicited_Write.

Exercise 4.4 – Report Writing (mark scheme)

Strong reports begin with the executive summary the plant manager actually reads, ranked by *process impact* not CVSS, with reproduction the asset owner can run in 10 minutes.